2415446
Derek Agyei
29/07/25

Security Report for FinSecure Ltd (FSL)

Table Of Contents

Security Report for FinSecure Ltd (FSL) 1
Table Of Contents 1
1. Abstract 1
2. Introduction 1
3. Identification of Threats 1
3.1 Internal Threats 1
3.2 External Threats 1
3.3 Linking Insider and External Threats 1
4. Security Policies for FinSecure Ltd (FSL) 1
4.2 Employee Awareness, Access Control, and Data Protection Policy 1
5.Mitigation Measures 1
6. Monitoring and Response 1
6.1 Monitoring 1
6.2 Response 1
7. Training and Awareness 1
8. Conclusion 1
9. References 1

1. Abstract

This report looks at the security challenges facing FinSecure Ltd (FSL), a medium-sized financial services organisation. Weaknesses such as human error, phishing, and the lack of strong technical defences like firewalls and intrusion prevention systems (IPS) were found [1][2].

The main risks are phishing, brute force attacks, credential stuffing, and Distributed Denial of Service (DDoS), which threaten FSL's operations, data integrity, and customer trust [3][4]. To reduce these, the report recommends policies based on the CIA Triad [7]. Measures include staff training, access control, multi-factor authentication (MFA), data encryption, intrusion detection and prevention systems (IDS/IPS) [5], firewalls, and DDoS protection [9].

This report finds that by combining staff awareness with technical controls and by following standards such as ISO/27001, the NIST Cybersecurity Framework (CSF) [6], and GDPR [14], FSL can increase its defences and respond effectively to current risks.

2415446
Derek Agyei
29/07/25

2. Introduction

Figure B

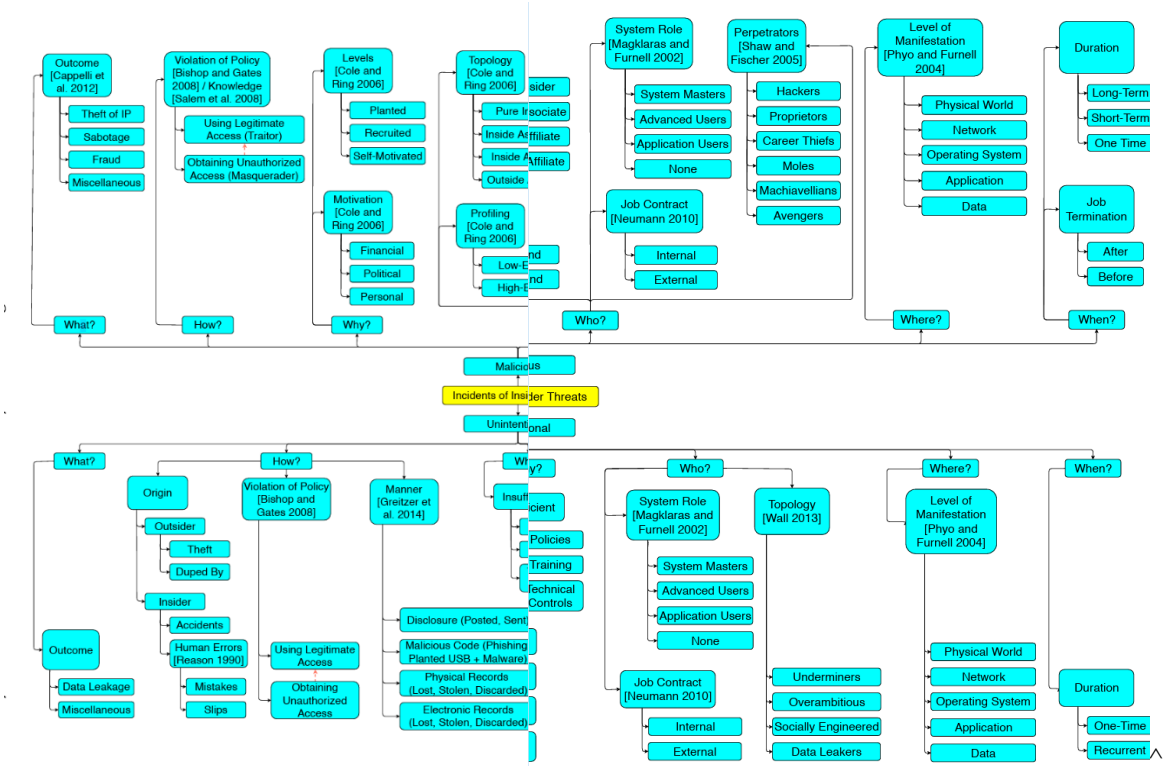


Figure A: Derek's Network Traffic Analysis in Wireshark for

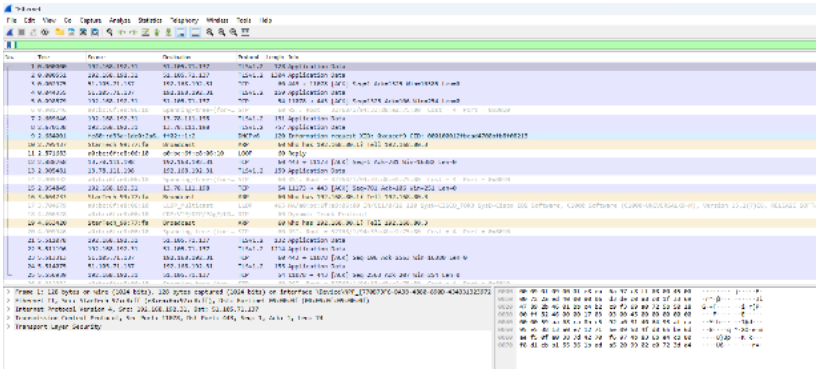


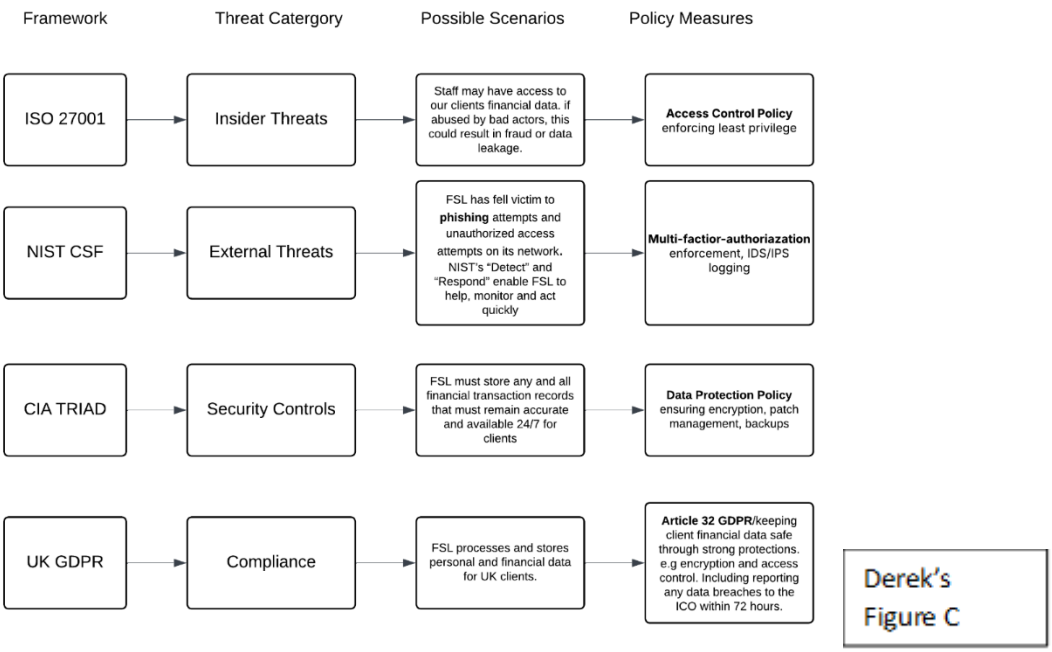
Figure B illustrates the taxonomy of insider threats, presenting a visual representation of several types of threats and implications for FSL's security strategy [1].

To effectively address security challenges, FSL's policy utilises accredited frameworks and standards. Insider threats are managed through ISO/27001, external defences are guided by the NIST Cybersecurity Framework (CSF), control design is structured by the CIA Triad, and compliance with the UK GDPR ensures lawful handling of customer data. Together, these frameworks provide a balance of technical defences, regulatory compliance, and practical controls.

ISO/27001 helps protect against insider threats by enforcing least-privilege access, limiting employees to only the permissions necessary for their role. This reduces risks such as staff misuse of accounts or accidental actions like clicking on phishing emails [1]. The NIST CSF, meanwhile, provides structured defences against external attacks, including phishing and brute force attempts. Its

five functions, Identify, Protect, Detect, Respond, and Recover, are supported by measures such as MFA, network monitoring, and incident response planning [10]. The detect function is particularly significant, as it enables the early identification of security incidents. Wireshark shows this by capturing and analysing network activity [12]. Figure A shows a practical example of Wireshark in use, capturing traffic [12].

The CIA Triad, which offers a straightforward way to design controls that will guarantee that confidentiality is protected with encryption and access limits, integrity is kept with patch management and change control, and availability is supported with high availability servers and DDoS protection [7]. The UK GDPR ensures that we oversee customer financial data lawfully and securely. FSL must limit data collection, implement privacy by design, and encrypt sensitive information to avoid fines of up to €20 million or 4% of annual turnover [9][14]. It is equally important to report breaches to the Information Commissioner's Office (ICO) when needed, as even a single incident could severely undermine the company's credibility and customer trust [14].



Derek's Figure C

- **ISO 27001 – Insider Threats**
  ISO 27001 prevents staff misuse by ensuring employees only have the access they need [1].
- **NIST-External Threats**: Detects and responds to outside attacks such as brute force and phishing [10].
- **CIA Triad Controls**: Ensures confidentiality (encryption), integrity (patching/change control), and availability (DDoS protection) [7].
- **UK GDPR Compliance:** Requires lawful handling of customer data, breach reporting, and penalties for non-compliance [14].

By integrating ISO/27001, NIST CSF, the CIA Triad, and GDPR, FSL establishes a comprehensive security framework that safeguards both staff and customer data.

2415446
Derek Agyei
29/07/25

3. Identification of Threats

FSL faces linked internal and external threats; policies like ISO/27001 address insider threats, NIST CSF provides structured defences, the CIA Triad keeps comprehensive control design, and UK GDPR guarantees data protection compliance.

3.1 Internal Threats

Human error and negligence have made FSL vulnerable to phishing attempts, showing how social engineering can bypass technical controls by fooling employees into harmful actions such as fraud, theft of confidential information, and sabotage of IT systems. As shown in Figure B, some insider threats are malicious, and many employees make unintentional errors [1].

Employees, whether acting intentionally or unintentionally, may cause damage to organisational systems and data. In our case, negligence has been more noticeable than malice. As the National Cyber Security Centre (NCSC) explains, “Phishing is an attack that attempts to steal your money, or your identity, by getting you to reveal personal information.” [15]. It is quite clear that our staff have been susceptible to these tactics, which allowed attackers to bypass our network security.

Additionally, ransomware has also become one of the most significant external threats facing financial organisations like FSL and even healthcare, e.g., the NHS “WannaCry”. Verizon’s 2023 Data Breach Investigations Report shows that it is rising across the financial sector, often causing prolonged downtime and monetary losses [11]. Phishing keeps being a common strategy, with staff tricked into opening attachments that install malware and other malicious software [15]. Attackers often commonly combine techniques, such as launching DDoS attacks to distract IT teams while deploying ransomware infections in the background [9][11]. For FSL, this could crash financial services, damage customer trust, and bring on regulatory penalties.

3.2 External Threats

Attackers may have tried unauthorised access attempts to FSL by using brute force attacks, repeatedly trying many password combinations to compromise accounts. As Microsoft notes, “An attacker will try multiple password attempts against a targeted set of accounts. In many cases, these accounts will be targeted against users who have a higher level of access within the organisation." Such privileged accounts, including executives or system administrators, are particularly attractive to attackers because they grant access to critical systems and infrastructure [8].

This leads to credential stuffing, where attackers use stolen login details from our data breaches. This technique is especially effective when employees reuse passwords across multiple accounts. If successful, attackers could gain unauthorised access to financial records, customer accounts, or internal managerial administrative systems. Additionally, exposing sensitive customer information could lead FSL to breach regulatory requirements such as the General Data Protection Regulation (GDPR), resulting in severe fines and legal liabilities [14].

Another major risk comes from Distributed Denial of Service (DDoS) attacks [9]. In this scenario, attackers flood our network or online banking systems with overwhelming amounts of traffic, disrupting services and denying access to legitimate users. Besides causing immediate service

disruption, DDoS can serve as a diversion tactic, occupying IT resources while attackers conduct other intrusions such as credential stuffing [11]. This shows how DDoS and credential-based attacks can work in tandem: the first creating a smokescreen, while the second quietly compromises employee accounts.

3.3 Linking Insider and External Threats

The incidents previously mentioned show that FSL faces a dual challenge. Insider threats originate from human error, negligence, or potential malice. In contrast, external actors employ techniques such as brute force, credential stuffing, phishing, and Distributed Denial of Service (DDoS) attacks to prey on the uninformed; they also use these techniques to exploit internal weaknesses, such as poor passwords and insufficient awareness. These areas show how external attackers exploit internal weaknesses, including poor password practices and lack of employee awareness, to gain unauthorised access [11][15]. Technical measures alone are insufficient for defence; they must be complemented by employee training and awareness to effectively prevent threats [13][15].

4. Security Policies for FinSecure Ltd (FSL)

FSL must adopt a comprehensive security policy framework to protect against insider and external threats. This will boost privacy protections and improve employee behaviour and compliance with the General Data Protection Regulation (GDPR) [7][14]. Without such measures, both our customers and our operations will remain at significant risk. The following policy will form the foundation of a secure operating environment. Touching upon GDPR's rules and regulations, FSL will set up a formal breach reporting system. All suspected data breaches must be reported at once to the IT Security Manager, which will then be escalated to senior leadership. Simultaneously, we will contact the Information Commissioner's Office (ICO) within 72 hours [14]. All our clients will be told if they are affected by data breaches. Staff will receive training on recognising and reporting breaches.

4.2 Employee Awareness, Access Control, and Data Protection Policy

A comprehensive Employee Awareness and Training Programme will be designed to reduce the risks of phishing, social engineering, and negligent security practices. This will increase awareness of cyber threats and actively prevent future incidents. Employees will be trained to find and report phishing attempts, as well as to create strong passwords by the company's cybersecurity policies.

Employee Training and Support: All staff will complete cybersecurity training during onboarding, followed by regular refresher courses to adapt to evolving threats [13]. Customer-facing departments will receive more attention, as they handle large volumes of information and are prime targets for phishing campaigns. Security reminders will be distributed across newsletters, posters, and awareness campaigns, reinforcing key areas such as phishing recognition, password safety, and safe internet/email practices. Employees must report suspicious emails, attachments, or links at once to the IT security team [15].

2415446
Derek Agyei
29/07/25
Access Control and Privileged Accounts: To support confidentiality and integrity, FSL will enforce the principle of least privilege. Employees will only access the systems needed for their roles [14]. Privileged accounts, particularly for senior staff and administrators handling sensitive data, will undergo stricter oversight, periodic reviews, and refresher training to minimise risks [14].

Multi-Factor Authentication and Encryption: MFA will be mandatory for all privileged accounts and sensitive systems. MFA reduces risks by requiring verification beyond passwords [6]. To prevent unauthorised disclosure or misuse, FSL will also enforce a data encryption policy, guaranteeing that private clients' and business related data is encrypted while in transit [14].

This CIA-aligned policy addresses FSL's most serious vulnerability: human error. By combining awareness training, access control, MFA, and encryption, FSL will protect **Confidentiality** through restricted access and encryption, uphold **Integrity** by ensuring data cannot be tampered with, and support **Availability** by reducing risks of compromised accounts [7][14].

Intrusion Detection and Prevention Policy

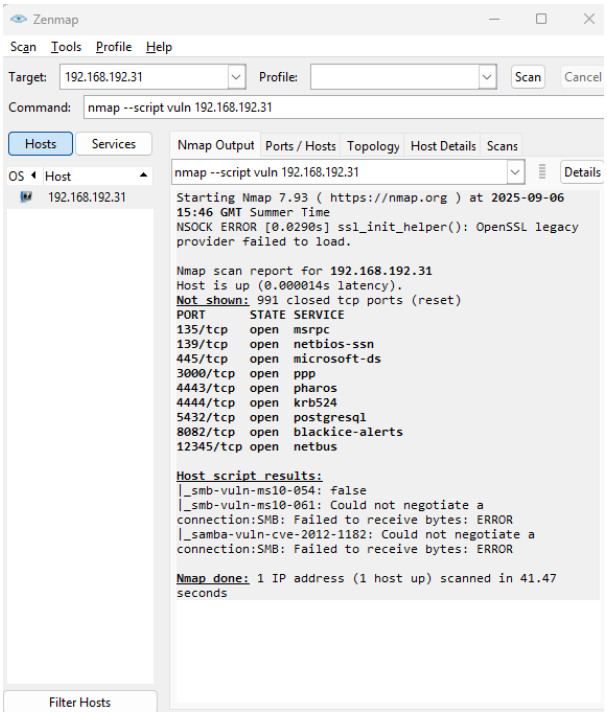
FSL will use IDS/IPS to send real time warnings of unauthorised access attempts. Network traffic will be monitored by these systems, which will also detect possible brute force or credential stuffing attacks and prevent dangerous attacks like DDoS attacks [5][9]. To bolster defences and aid investigations, logs will be examined, setting up a trail that can be utilised to reconstruct events [5].

The IDS will also keep detailed logs of attempted breaches. These will be checked to improve defences and help with investigations. In usage, this means the IDS alerts the security team about unusual activity in real time. For example, repeated failed login attempts, trying to tamper with server files, or strange traffic patterns would be flagged and logged. These records provide a forensic trail, making it easier to work out what happened and close gaps in the future [5].

Firewalls will act as barriers that divide internal systems and untrusted networks, making sure only approved services like banking portals and email are available. They will also record traffic activity to help with threat detection. Logs from IDS/IPS, firewalls, and applications will be sent into a central SIEM (e.g., Splunk) and be kept for at least 12 months [17]. By combining training, access control, MFA, encryption, IDS/IPS, and firewalls, this policy tackles FSL's biggest weakness, human error, while keeping confidentiality, integrity, and availability in place [7][14].

2415446
Derek Agyei
29/07/25

5. Mitigation Measures

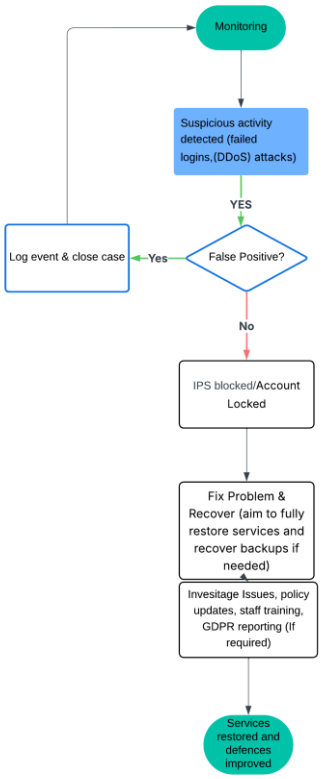


- Tools such as Nmap allow the security team and attackers to show open ports and services on a network [12][21]. Each open port provides easy access for an attack. Attackers will try to exploit the open ports, while administrators aim to close or protect them with firewalls without hindering legitimate users [5][21]. For instance, a test Nmap scan was done on a sample system (Figure N), revealing open ports 135 and 445. Without proper controls on FSL's network, attackers could target the company to gain unauthorised access or exploit known weaknesses.
- Employee Training: All employees must complete cybersecurity training during onboarding; they must also undergo mandatory refresher training every six months [13].
- System Updates and Patching/Firewall: A patch management policy is regular system and application updates, and it asks that critical patches should be deployed within 48 hours. A security system will be used to provide strong security and defend the network against online threats [19].
- Multi Factor Authentication (MFA) will be needed for all privileged and sensitive accounts [6].
- Network Monitoring: IDS/IPS systems will send prompt alerts of anomalies, like recurring login failures or DDoS spikes, by feeding data into a centralised monitoring solution [5].
- Anti Malware Solutions: All devices will use locally managed anti malware software with daily updates, real time scanning, and Endpoint Detection and Response (EDR) capabilities for advanced threat detection [19][20].

2415446
Derek Agyei
29/07/25

6. Monitoring and Response

6.1 Monitoring



IDS/IPS: these systems will continuously detect and inspect network traffic for anomalies, such as brute force attempts, credential stuffing, or abnormal spikes associated with DDoS attacks [5][9]. IPS actively block suspicious activity in real-time, to guarantee a rapid containment of threats.

Log Retention and SIEM: Security information will be collected from multiple sources, including firewalls, IDS/IPS, and application logs. These logs will be stored within a SIEM platform, such as Splunk [17], which enables real time correlation, alerting, and visual dashboards. The company will keep logs for at least 12 months to make sure that incidents can be analysed if found later, supporting forensic investigations and regulatory compliance [19][20].

6.2 Response

Reliability of Logs: Each log source will be regularly checked for accuracy, completeness, and timeliness to ensure data can be trusted during incident investigations. [19] [20].
Network Scanning: Consistent vulnerability and port scans using tools, such as Nmap, will support monitoring by proactively showing exposed services that attackers could exploit [12][21].
Setting up IDS/IPS systems, log retention, and SIEM platforms will further improve FSL's ability to detect and hold threats, effectively supporting the CIA Triad [7].

7. Training and Awareness

- All employees will be trained on phishing, social engineering, password practices, and incident reporting.
- Refresher training will be held every six months to address new threats [13].
- Customer facing roles will receive enhanced training due to their vulnerability to phishing attacks [15].
- We will conduct regular phishing simulations to assess staff awareness and response to simulated attacks [15].
- Awareness campaigns, such as posters, newsletters, and internal updates, will keep security at the forefront of staff members' minds [13].

8. Conclusion

All current risks will be addressed through stricter access control, multi factor authentication (MFA), encryption, IDS/IPS, and firewalls to make sure that only authorised staff can access critical systems and sensitive information stays protected. External threats will be carefully watched by trusted vendors such as Cloudflare, helping keep services available during an attack as they block malicious traffic before it reaches our network [9]. By applying these technical controls with key frameworks like the CIA Triad, ISO/27001, NIST CSF, and GDPR, FSL will protect its systems and data while also staying compliant with regulations.

9. References

[1] I. Homoliak, F. Toffalini, J. Guarnizo, Y. Elovici, and M. Ochoa, "Insight into Insiders and IT: A Survey of Insider Threat Taxonomies, Analysis, Modelling, and Countermeasures," *ACM Computing Surveys*, vol. 52, no. 2, pp. 1–40, 2018. [Online]. Available: https://arxiv.org/pdf/1805.01612

[2] P. Wadhwa, "Beyond Checkboxes: How Compliance Controls Protect Your Organization?," *Sprinto*, Sep. 2025. [Online]. Available: https://sprinto.com/blog/compliance-controls/ (accessed Sep. 10, 2025).

[3] Information Commissioner's Office (ICO), "UK GDPR guidance and resources," *ICO*, Aug. 2025. [Online]. Available: https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/ (accessed Aug. 24, 2025).

[4] National Institute of Standards and Technology (NIST), *Cybersecurity Framework (CSF) 2.0*, Gaithersburg, MD, USA: NIST, 2024. [Online]. Available: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf

[5] A. Kak, "Lecture 23: Port and Vulnerability Scanning, Packet Sniffing, Intrusion Detection, and Penetration Testing," *Purdue University*, 2024. [Online]. Available: https://engineering.purdue.edu/kak/compsec/NewLectures/Lecture23.pdf

[6] Tekclarion, "A Comparative Guide to Cybersecurity Frameworks: NIST CSF v2.0, ISO/IEC 27001:2022, and CIS Controls v8," *Tekclarion*, Aug. 2025. [Online]. Available: https://www.tekclarion.com/cyber-security/a-comparative-guide-to-cybersecurity-frameworks-nist-csf-v2-0-iso-iec-270012022-and-cis-controls-v8/ (accessed Aug. 25, 2025).

[7] Delinea Team, "What is the CIA Triad? Key components and examples," *Delinea*, Aug. 2025. [Online]. Available: https://delinea.com/blog/what-is-the-cia-triad-key-components-and-examples (accessed Aug. 25, 2025).

[8] Microsoft, "What is a password attack?," *Microsoft Learn*, Aug. 2025. [Online]. Available: https://learn.microsoft.com/en-us/windows-server/identity/ad-fs/technical-reference/ad-fs-password-protection (accessed Aug. 24, 2025).

[9] Cloudflare, "What is a DDoS attack?," *Cloudflare*, Aug. 2025. [Online]. Available: https://www.cloudflare.com/learning/ddos/what-is-a-ddos-attack/ (accessed Aug. 24, 2025).

[10] Exabeam, "What Is an Insider Threat? Understand the Problem and Discover 4 Defensive Strategies," *Exabeam*, Sep. 2025. [Online]. Available: https://www.exabeam.com/explainers/insider-threats/insider-threats/ (accessed Sep. 5, 2025).

[11] Verizon, *2023 Data Breach Investigations Report – Public Sector Snapshot*. Verizon, 2023. [Online]. Available: https://www.verizon.com/business/resources/Ta5a/reports/2023-dbir-public-sector-snapshot.pdf

[12] G. F. Lyon, *Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning*. Sunnyvale, CA, USA: Nmap Software LLC, 2009. [Online]. Available: https://nmap.org/book/

[13] SANS Institute, "Security Awareness Training: Best Practices," *SANS Institute*, 2025. [Online]. Available: https://www.sans.org/security-awareness-training/ (accessed 2025).

[14] European Union, *General Data Protection Regulation (GDPR)*, Regulation (EU) 2016/679, Brussels, Belgium, 2016. [Online]. Available: https://gdpr-info.eu/

[15] National Cyber Security Centre (NCSC), "Phishing attacks: dealing with suspicious emails, phone calls and text messages," *NCSC*, 2025. [Online]. Available: https://www.ncsc.gov.uk/collection/phishing-scams (accessed 2025).

[16] MITRE ATT&CK, "Brute Force Technique (T1110)," *MITRE*, 2025. [Online]. Available: https://attack.mitre.org/techniques/T1110/ (accessed 2025).

[17] Splunk, "What is SIEM? Security Information and Event Management explained," *Splunk*, 2025. [Online]. Available: https://www.splunk.com/en_us/data-insider/what-is-siem.html (accessed 2025).

[18] Center for Internet Security (CIS), "Critical Security Controls v8," *CIS*, 2025. [Online]. Available: https://www.cisecurity.org/controls/v8 (accessed 2025).

[19] Rapid7, "Log Management and Retention Best Practices," *Rapid7*, 2025. [Online]. Available: https://www.rapid7.com (accessed 2025).

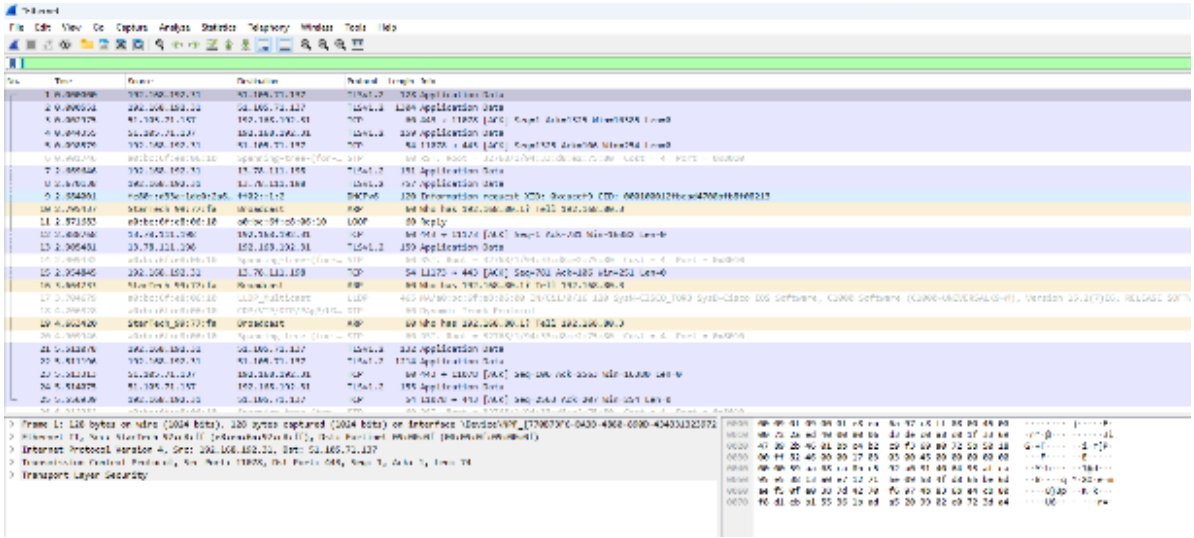
[20] OWASP, "Port Scanning and Enumeration," *OWASP Foundation*, 2025. [Online]. Available: https://owasp.org/www-community/attacks/Port_Scanning (accessed 2025).

Appendix

Appendix A: Wireshark Traffic Capture

Wireshark capture showing suspicious activity and illustrating the *Detect* function of the NIST Cybersecurity Framework (CSF).

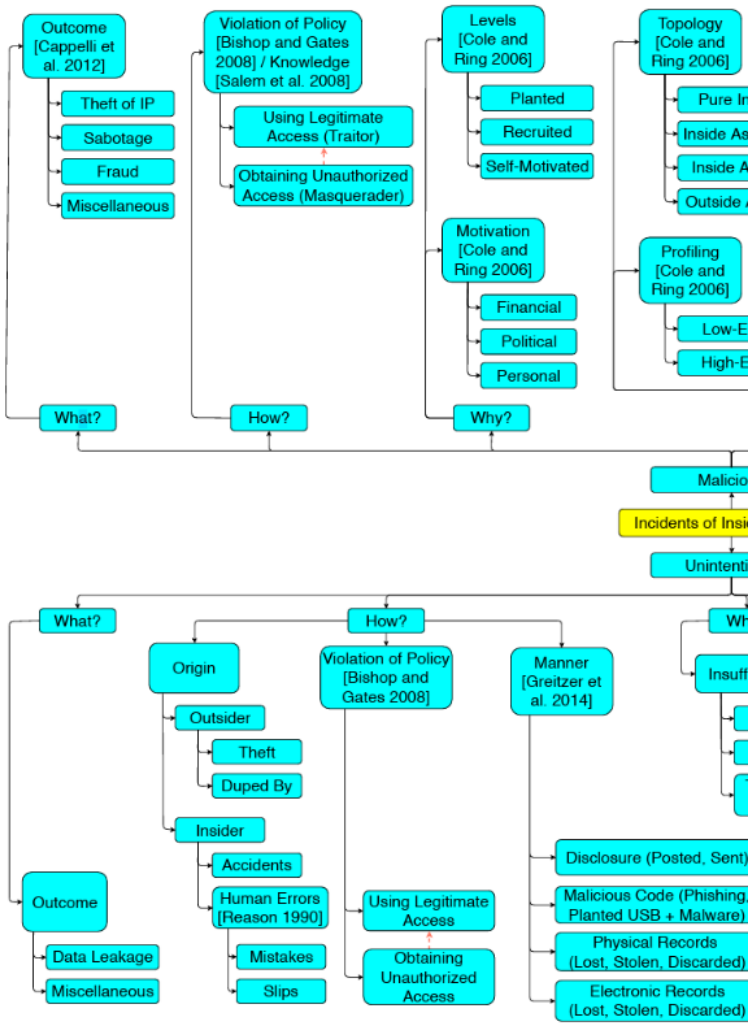
2415446
Derek Agyei
29/07/25



Appendix B: Insider Threat Taxonomy

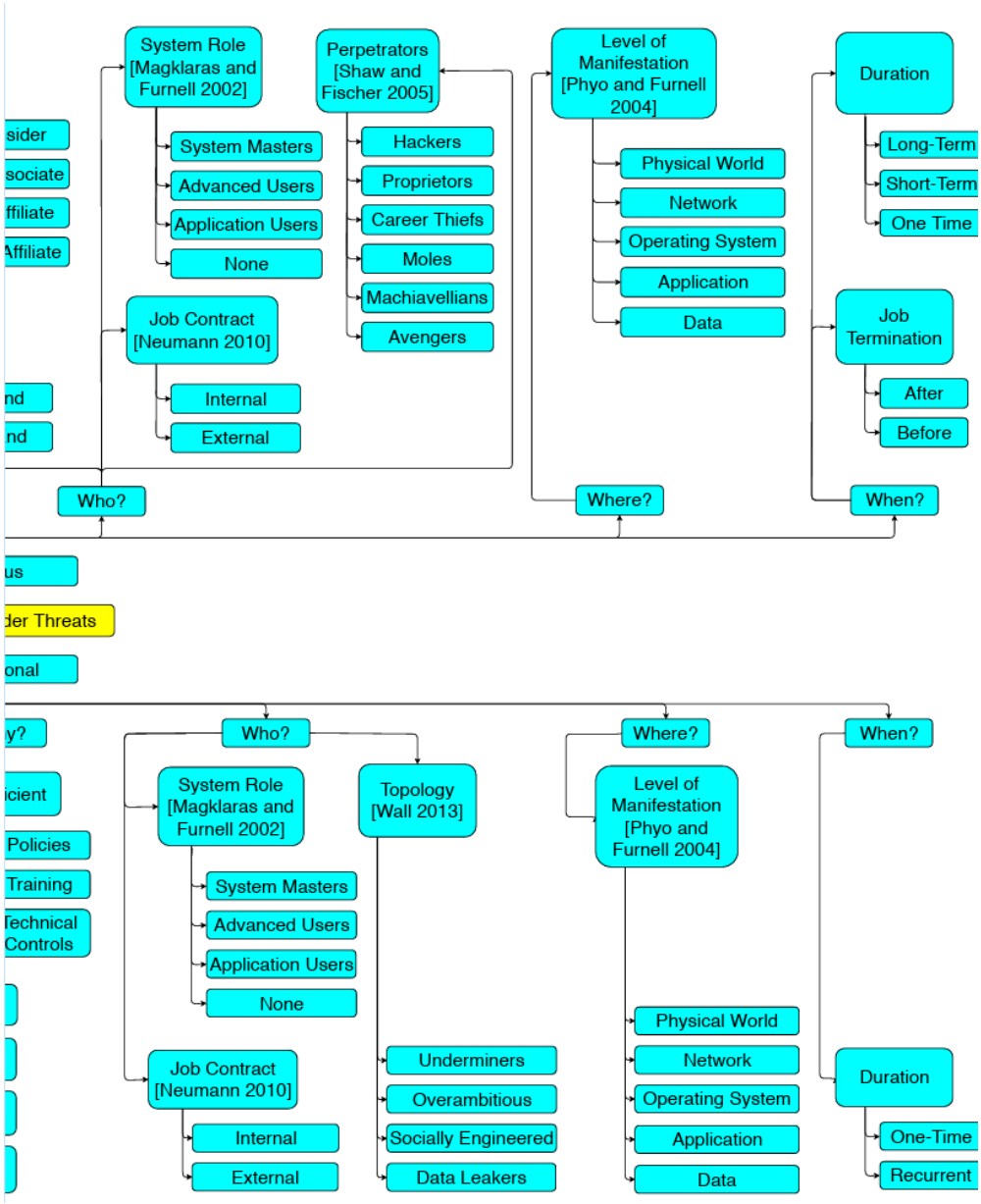
of insider threats, showing unintentional and malicious behaviours and their implications for FinSecure Ltd.

2415446
Derek Agyei
29/07/25



from Homoliak et al. [1]

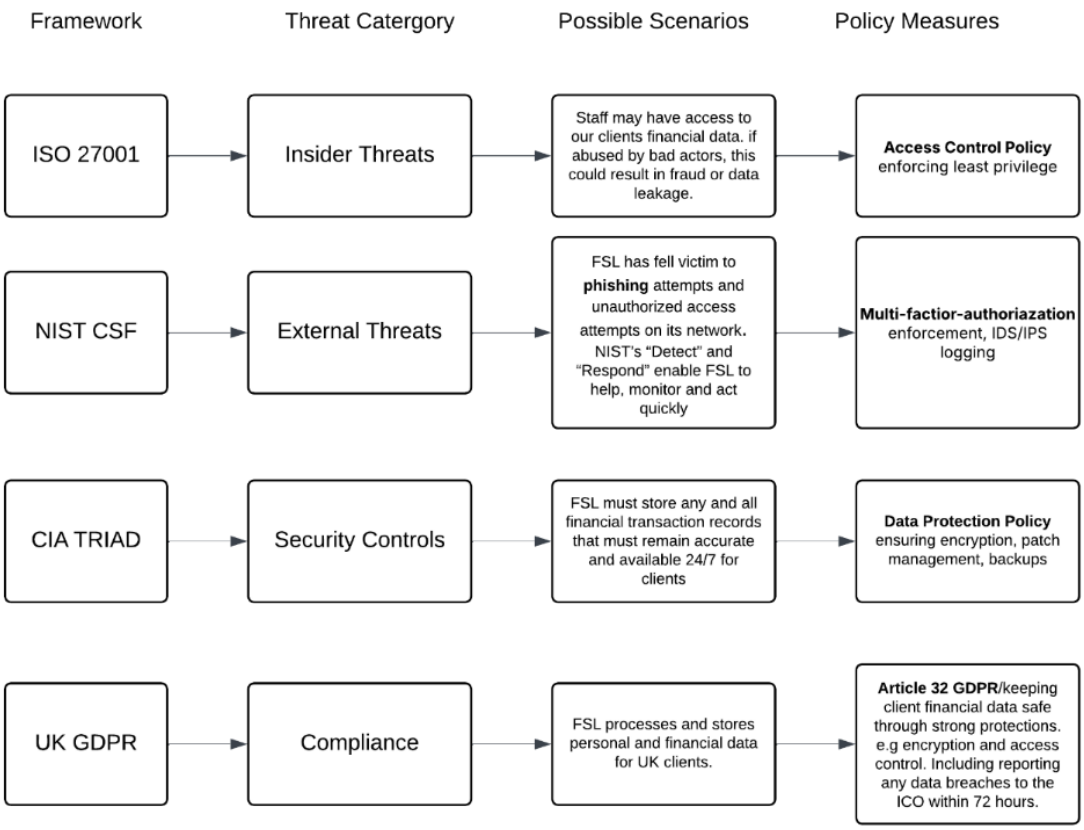
2415446
Derek Agyei
29/07/25



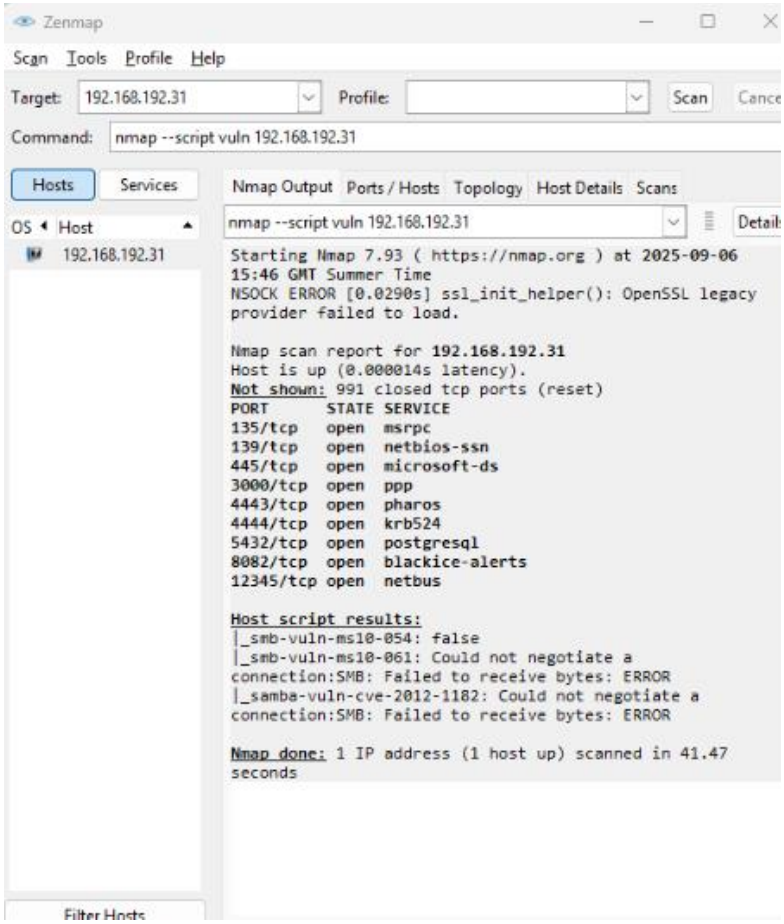
Appendix C: Framework Integration Overview

Diagram showing how ISO/27001, the NIST CSF, the CIA Triad, and GDPR integrate to form a

2415446
Derek Agyei
29/07/25
comprehensive security framework.



Appendix D: Nmap Port Scan Example

Screenshot of an Nmap scan showing open ports (135 and 445) and potential risks if left unpatched.

2415446
Derek Agyei
29/07/25